

Personal Loan Application System

API Specification Document

Field-Level Technical Reference for All 8 Modules

Property	Value
Document Type	API Specification Document
Project	Personal Loan Application System
Version	1.0
Base URL	https://api.personalloan.com/api/v1
Protocol	HTTPS only
Auth Mechanism	JWT Bearer Token
Content-Type	application/json
Date Format	ISO 8601 (yyyy-MM-ddTHH:mm:ssZ)
Total Modules	8
Total Endpoints	55+

Module 1 — Authentication APIs

Base Path: /api/v1/auth

Handles user registration, login, token management, and password operations. All secured endpoints require a valid JWT Bearer Token.

1.1 Register User

POST /api/v1/auth/register — Register a new customer account

Property	Value
Method	POST
Endpoint	/api/v1/auth/register
Description	Register a new customer account
Auth Required	No
Allowed Roles	PUBLIC

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
firstName	String	Yes	Min 2, Max 50 chars. Only letters allowed. No numbers.	Rohan
lastName	String	Yes	Min 2, Max 50 chars. Only letters allowed.	Patil
email	String	Yes	Valid email format. Must be unique in system.	rohan@gmail.com
mobileNumber	String	Yes	Exactly 10 digits. Must be unique. No spaces/dashes.	9876543210
password	String	Yes	Min 8 chars. Must have 1 uppercase, 1 digit, 1 special.	SecurePass@123
confirmPassword	String	Yes	Must match password exactly.	SecurePass@123

Response Body — Field Specification

Field Name	Type	Description	Example
success	Boolean	true = success	true
message	String	Confirmation message	User registered successfully. Please verify your email.
data.userId	Long	Auto-generated system user ID	1
data.email	String	Registered email address	rohan@gmail.com
statusCode	Integer	HTTP status code	201

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Validation failed (missing/invalid fields)	firstName is required / email is not valid
409	Email already registered	Email address is already registered
409	Mobile number already registered	Mobile number already exists in the system

Business Rules

- Email verification link is sent automatically after successful registration.
- User account is inactive until email is verified.
- Password is hashed using BCrypt (strength 10) before storing. Never stored in plaintext.

1.2 Login

POST /api/v1/auth/login — Authenticate user and receive JWT tokens

Property	Value
Method	POST
Endpoint	/api/v1/auth/login
Description	Authenticate user and receive JWT tokens
Auth Required	No
Allowed Roles	PUBLIC

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
email	String	Yes	Registered email address.	rohan@gmail.com
password	String	Yes	Account password (plain text, hashed on server).	SecurePass@123

Response Body — Field Specification

Field Name	Type	Description	Example
data.accessToken	String	JWT access token — valid for 24 hours	eyJhbGci...
data.refreshToken	String	Refresh token — valid for 7 days	dGhpcyBpcyA...
data.tokenType	String	Always 'Bearer'	Bearer
data.expiresIn	Long	Access token expiry in seconds (86400 = 24h)	86400
data.role	String	User role: CUSTOMER / LOAN_OFFICER / ADMIN etc	CUSTOMER

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Missing email or password	email is required
401	Invalid credentials	Invalid email or password
403	Account locked or suspended	Your account has been locked. Please contact support.
403	Email not verified	Please verify your email before logging in.

Business Rules

- Access Token expires in 24 hours (86400 seconds).
- After 5 consecutive failed login attempts, account is automatically locked.

- Locked accounts must be unlocked by ADMIN.

1.3 Forgot Password

POST `/api/v1/auth/forgot-password` — Send password reset link to registered email

Property	Value
Method	POST
Endpoint	/api/v1/auth/forgot-password
Description	Send password reset link to registered email
Auth Required	No
Allowed Roles	PUBLIC

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
email	String	Yes	Must be a registered email in the system.	rohan@gmail.com

Response Body — Field Specification

Field Name	Type	Description	Example
success	Boolean	Always true (even if email not found — for security)	true
message	String	Confirmation message	Password reset link sent to your email.
statusCode	Integer	HTTP status code	200

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Email field missing	email is required
400	Invalid email format	email must be a valid email address

Business Rules

- For security, a 200 OK is returned even if the email is not registered (prevents email enumeration).
- Reset token is valid for 15 minutes only.
- Only one active reset token allowed per user at a time.

1.4 Reset Password

POST /api/v1/auth/reset-password — Reset password using the token from reset email

Property	Value
Method	POST
Endpoint	/api/v1/auth/reset-password
Description	Reset password using the token from reset email
Auth Required	No
Allowed Roles	PUBLIC

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
token	String	Yes	Token received in the reset email link. Valid for 15 minutes.	reset-token-from-email
newPassword	String	Yes	Min 8 chars. Must have 1 uppercase, 1 digit, 1 special char.	NewPass@456
confirmPassword	String	Yes	Must exactly match newPassword.	NewPass@456

Response Body — Field Specification

Field Name	Type	Description	Example
success	Boolean	true = password reset successful	true
message	String	Confirmation message	Password reset successfully.

Field Name	Type	Description	Example
statusCode	Integer	HTTP status code	200

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Token missing or invalid format	token is required
400	New password does not meet requirements	password must contain at least 1 uppercase letter
400	Passwords do not match	confirmPassword must match newPassword
401	Token expired or already used	Password reset token is expired or invalid

Business Rules

- Reset token is invalidated immediately after use (single-use token).
- New password cannot be the same as the current/old password.

Module 2 — Customer APIs

Base Path: /api/v1/customers

Manages customer personal information, address, employment details, and KYC identity data.

2.1 Create Customer Profile

POST /api/v1/customers/profile — Create detailed customer profile after registration

Property	Value
Method	POST
Endpoint	/api/v1/customers/profile
Description	Create detailed customer profile after registration
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CUSTOMER

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
firstName	String	Yes	Min 2, Max 50 chars. Letters only.	Rohan
lastName	String	Yes	Min 2, Max 50 chars. Letters only.	Patil
dateOfBirth	Date	Yes	Format: yyyy-MM-dd. Customer must be >= 21 and <= 65 years old.	1995-06-15
gender	Enum	Yes	Allowed values: MALE, FEMALE, OTHER	MALE
fatherName	String	Yes	Min 2, Max 100 chars.	Suresh Patil
mobileNumber	String	Yes	Exactly 10 digits. Must match registered mobile.	9876543210
email	String	Yes	Valid email. Must match registered email.	rohan@gmail.com

Field Name	Type	Required	Validation Rules	Example
panNumber	String	Yes	Format: [A-Z]{5}[0-9]{4}[A-Z]{1}. Example: ABCDE1234F. Unique.	ABCDE1234F
aadhaarNumber	String	Yes	12-digit Aadhaar. Format: XXXX XXXX XXXX. Must be unique.	1234 5678 9012
address.street	String	Yes	Min 5, Max 200 chars.	123 MG Road
address.city	String	Yes	Min 2, Max 100 chars. Letters only.	Pune
address.state	String	Yes	Valid Indian state name.	Maharashtra
address.pincode	String	Yes	Exactly 6 digits. Valid Indian PIN code.	411001
employmentType	Enum	Yes	Allowed: SALARIED, SELF_EMPLOYED, BUSINESS_OWNER	SALARIED
companyName	String	Cond	Required if employmentType = SALARIED. Min 2, Max 200 chars.	TCS
monthlyIncome	Decimal	Yes	Min value: 10000.00. Max value: 10000000.00	75000.00

Response Body — Field Specification

Field Name	Type	Description	Example
data.customerId	Long	Auto-generated customer ID	101
data.panNumber	String	PAN number confirmed	ABCDE1234F
statusCode	Integer	HTTP status code	201

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Validation failure on any field	panNumber format is invalid

HTTP Code	Scenario	Error Message
400	Customer age below 21 or above 65	Date of birth: customer must be between 21 and 65 years old
409	PAN number already exists	PAN number already exists in the system
409	Aadhaar number already exists	Aadhaar number already registered
401	Unauthorized — no valid JWT token	Authentication token is missing or invalid

Business Rules

- Customer must be between 21 and 65 years of age at the time of profile creation.
- PAN number and Aadhaar number must be unique across the system.
- One registered user can have only one customer profile.
- Loan applications can only be submitted after a complete customer profile exists.

2.2 Get Own Profile

GET /api/v1/customers/profile — Retrieve the profile of the currently logged-in customer

Property	Value
Method	GET
Endpoint	/api/v1/customers/profile
Description	Retrieve the profile of the currently logged-in customer
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CUSTOMER

Response Body — Field Specification

Field Name	Type	Description	Example
customerId	Long	Unique customer identifier	101
firstName	String	Customer first name	Rohan

Field Name	Type	Description	Example
lastName	String	Customer last name	Patil
email	String	Registered email address	rohan@gmail.com
mobileNumber	String	Registered mobile number	9876543210
panNumber	String	PAN number (partially masked for security)	ABCDE****F
aadhaarNumber	String	Aadhaar number (masked: XXXX XXXX 9012)	XXXX XXXX 9012
employmentType	Enum	SALARIED / SELF_EMPLOYED / BUSINESS_OWNER	SALARIED
monthlyIncome	Decimal	Monthly income in INR	75000.00
address	Object	Full address object with street, city, state, pin	{ ... }
createdAt	DateTime	Profile creation timestamp in ISO 8601	2026-01-15T09:30:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
401	No JWT token provided	Authentication token is missing or invalid
404	Profile not yet created	Customer profile not found. Please complete your profile.

2.3 Get All Customers (Admin/Officer)

GET /api/v1/customers — Get all customers with pagination (Admin/Loan Officer only)

Property	Value
Method	GET
Endpoint	/api/v1/customers
Description	Get all customers with pagination (Admin/Loan Officer only)
Auth Required	Yes — Bearer JWT Token
Allowed Roles	ADMIN, LOAN_OFFICER

Query Parameters

Parameter	Type	Required	Default	Description
page	Integer	No	0	Page number (0-indexed). Default: 0
size	Integer	No	10	Records per page. Max: 100
sortBy	String	No	createdAt	Sort field: createdAt, firstName, email
sortDir	String	No	desc	Sort direction: asc or desc
search	String	No	—	Search by name, email, or PAN

Response Body — Field Specification

Field Name	Type	Description	Example
content	Array	Array of customer profile objects	[{...}, {...}]
page	Integer	Current page number	0
size	Integer	Page size	10
totalElements	Long	Total number of customer records	150
totalPages	Integer	Total number of pages	15
last	Boolean	true if this is the last page	false

Possible Error Responses

HTTP Code	Scenario	Error Message
401	Unauthorized	Authentication token is missing or invalid
403	Wrong role	You do not have permission to access this resource

Module 3 — Loan APIs

Base Path: /api/v1/loans

Manages complete loan application lifecycle from DRAFT creation through DISBURSED final state.

3.1 Submit Loan Application

POST /api/v1/loans — Submit a new loan application

Property	Value
Method	POST
Endpoint	/api/v1/loans
Description	Submit a new loan application
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CUSTOMER

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
loanTypeId	Long	Yes	Valid loan type ID from GET /api/v1/loan-types	1
loanAmount	Decimal	Yes	Min: 10,000.00 Max: 5,000,000.00 INR only	500000.00
loanTenureMonths	Integer	Yes	Min: 6 months Max: 84 months (7 years)	36
purpose	String	Yes	Min 10, Max 500 chars. Reason for loan.	Home Renovation
employmentType	Enum	Yes	SALARIED, SELF_EMPLOYED, BUSINESS_OWNER	SALARIED
monthlyIncome	Decimal	Yes	Min: 15,000.00. Gross monthly income in INR.	75000.00
existingEMIs	Decimal	No	Total existing monthly EMI obligations. Default 0.	5000.00

Response Body — Field Specification

Field Name	Type	Description	Example
data.loanId	Long	Auto-generated unique loan ID	501
data.applicationNumber	String	Unique application reference number	LOAN20260628001
data.loanStatus	Enum	Initial status is always DRAFT	DRAFT
data.loanAmount	Decimal	Applied loan amount	500000.00
data.interestRate	Decimal	Interest rate applied (% per annum)	12.5
data.createdAt	DateTime	Application submission timestamp	2026-06-28T10:15:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
400	loanAmount below minimum	loanAmount must be at least 10,000
400	loanAmount above maximum	loanAmount cannot exceed 5,000,000
400	loanTenureMonths out of range	loanTenureMonths must be between 6 and 84
400	Invalid loanTypeId	Loan type with ID 1 not found
422	Customer profile incomplete	Please complete your customer profile before applying
422	FOIR exceeds 60%	Fixed Obligation to Income Ratio exceeds the allowed 60%
401	Unauthorized	Authentication token is missing or invalid

Business Rules

- Customer profile must be complete before submitting a loan application.
- FOIR (Fixed Obligation to Income Ratio) must not exceed 60%. $FOIR = (\text{existingEMIs} + \text{newEMI}) / \text{monthlyIncome}$.
- EMI is auto-calculated using the formula: $EMI = P \times r \times (1+r)^n / ((1+r)^n - 1)$

- Loan is created in DRAFT status. Customer must explicitly submit it for review.
- Application number format: LOAN{YYYYMMDD}{3-digit sequence}

3.2 Get Loan by ID

GET /api/v1/loans/{loanId} — Retrieve full details of a specific loan application

Property	Value
Method	GET
Endpoint	/api/v1/loans/{loanId}
Description	Retrieve full details of a specific loan application
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CUSTOMER, LOAN_OFFICER, CREDIT_MANAGER, FINANCE_OFFICER, ADMIN

Path Parameters

Parameter	Type	Required	Description
loanId	Long	Yes	Unique ID of the loan application

Response Body — Field Specification

Field Name	Type	Description	Example
loanId	Long	Loan unique identifier	501
applicationNumber	String	Application reference number	LOAN20260628001
loanStatus	Enum	Current loan status	UNDER_VERIFICATION
loanAmount	Decimal	Applied loan amount in INR	500000.00
approvedAmount	Decimal	Approved amount (null until approved)	500000.00
loanTenureMonths	Integer	Loan duration in months	36
interestRate	Decimal	Interest rate per annum (%)	12.5
emi	Decimal	Monthly EMI amount in INR	16680.00

Field Name	Type	Description	Example
purpose	String	Loan purpose description	Home Renovation
customer.customerId	Long	Linked customer ID	101
customer.name	String	Customer full name	Rohan Patil
loanType.loanTypeId	Long	Loan type ID	1
loanType.name	String	Loan type name	Personal Loan
createdAt	DateTime	Loan creation timestamp	2026-06-28T10:15:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
401	Unauthorized	Authentication token is missing or invalid
403	CUSTOMER accessing another's loan	You do not have permission to view this loan
404	Loan ID not found	Loan application with ID 501 not found

Business Rules

- CUSTOMER role can only access their own loan applications.
- LOAN_OFFICER, CREDIT_MANAGER, FINANCE_OFFICER, and ADMIN can access any loan.

3.3 Submit Loan for Review

PATCH `/api/v1/loans/{loanId}/submit` — Move loan from DRAFT to SUBMITTED status for officer review

Property	Value
Method	PATCH
Endpoint	<code>/api/v1/loans/{loanId}/submit</code>
Description	Move loan from DRAFT to SUBMITTED status for officer review
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CUSTOMER

Path Parameters

Parameter	Type	Required	Description
loanId	Long	Yes	ID of the loan in DRAFT status to be submitted

Response Body — Field Specification

Field Name	Type	Description	Example
data.loanId	Long	Loan ID	501
data.loanStatus	String	Updated status = SUBMITTED	SUBMITTED
data.submittedAt	DateTime	Submission timestamp	2026-06-28T10:30:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Loan is not in DRAFT status	Only DRAFT loans can be submitted for review
422	Required documents not uploaded	Please upload all mandatory documents before submitting
404	Loan ID not found	Loan application with ID 501 not found
403	Customer accessing another's loan	You do not have permission to perform this action

Business Rules

- Only loans in DRAFT status can be submitted.
- All mandatory documents (PAN, Aadhaar, Salary Slips, Bank Statement) must be uploaded before submission.
- Once submitted, the loan cannot be edited by the customer.

3.4 Loan Status Flow

From Status	Action	Performed By	To Status
DRAFT	Customer submits	CUSTOMER	SUBMITTED

From Status	Action	Performed By	To Status
SUBMITTED	Officer picks up	LOAN_OFFICER	UNDER_VERIFICATION
UNDER_VERIFICATION	Officer verifies	LOAN_OFFICER	VERIFIED
VERIFIED	Manager approves	CREDIT_MANAGER	APPROVED
VERIFIED	Manager rejects	CREDIT_MANAGER	REJECTED
APPROVED	Finance sanctions	FINANCE_OFFICER	SANCTIONED
SANCTIONED	Finance disburses	FINANCE_OFFICER	DISBURSED
DISBURSED	Fully repaid	SYSTEM	CLOSED
DRAFT/SUBMITTED	Customer cancels	CUSTOMER	CANCELLED

Module 4 — Document APIs

Base Path: /api/v1/documents

Manages upload, retrieval, and deletion of KYC and income documents required for loan processing.

4.1 Upload Document

POST /api/v1/documents/upload — Upload a KYC or income document (multipart/form-data)

Property	Value
Method	POST
Endpoint	/api/v1/documents/upload
Description	Upload a KYC or income document (multipart/form-data)
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CUSTOMER

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
loanId	Long	Yes	Valid loan ID that this document belongs to.	501
documentType	Enum	Yes	PAN_CARD AADHAAR_CARD SALARY_SLIP BANK_STATEMENT PHOTO ITR FORM_16	PAN_CARD
file	Binary	Yes	File upload. Allowed types: PDF, JPG, PNG. Max size: 5MB.	<file binary>

Response Body — Field Specification

Field Name	Type	Description	Example
data.documentId	Long	Auto-generated document ID	201

Field Name	Type	Description	Example
data.documentType	String	Document type uploaded	PAN_CARD
data.fileName	String	Stored file name on server	PAN_101.pdf
data.fileSize	Long	File size in bytes	204800
data.uploadedAt	DateTime	Upload timestamp	2026-06-28T10:20:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Missing loanId or documentType	loanId is required / documentType is required
400	No file attached	file is required
400	File type not allowed	Only PDF, JPG, PNG files are accepted
400	File too large	File size must not exceed 5MB
404	Loan ID not found	Loan application with ID 501 not found
422	Same document type already uploaded for this loan	PAN_CARD already uploaded for this loan

Business Rules

- Maximum file size: 5MB per file.
- Allowed file types: PDF, JPG, JPEG, PNG only.
- Each document type can be uploaded only once per loan application.
- Documents can only be uploaded while loan is in DRAFT or SUBMITTED status.

4.2 Document Types Reference

Document Type	Description	Required For	Required
PAN_CARD	Government-issued PAN card	All applicants	Mandatory
AADHAAR_CARD	Aadhaar ID card (address proof)	All applicants	Mandatory

Document Type	Description	Required For	Required
SALARY_SLIP	Latest 3 months salary slips	Salaried only	Mandatory (Salaried)
BANK_STATEMENT	Last 6 months bank statement	All applicants	Mandatory
ITR	Income Tax Returns (2 years)	Self-Employed only	Mandatory (Self-Employed)
PHOTO	Recent passport-size photograph	All applicants	Mandatory
FORM_16	Tax deduction certificate	Salaried (optional)	Optional

Module 5 — Approval APIs (Maker-Checker)

Base Path: /api/v1/approvals

Implements two-level Maker-Checker approval workflow. Loan Officer verifies (Maker). Credit Manager approves or rejects (Checker). Finance Officer sanctions and disburses.

5.1 Verify Loan (Maker — Loan Officer)

POST /api/v1/approvals/{loanId}/verify — Loan Officer verifies documents and marks loan as VERIFIED

Property	Value
Method	POST
Endpoint	/api/v1/approvals/{loanId}/verify
Description	Loan Officer verifies documents and marks loan as VERIFIED
Auth Required	Yes — Bearer JWT Token
Allowed Roles	LOAN_OFFICER

Path Parameters

Parameter	Type	Required	Description
loanId	Long	Yes	ID of the loan in UNDER_VERIFICATION status

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
remarks	String	Yes	Min 10, Max 1000 chars. Officer's verification remarks.	All documents verified. Income eligibility confirmed.
recommendedAmount	Decimal	Yes	Recommended loan amount. Must be <= applied loanAmount.	500000.00

Response Body — Field Specification

Field Name	Type	Description	Example
data.loanStatus	String	Updated status = VERIFIED	VERIFIED
data.verifiedBy	String	Name of the loan officer	Officer Sharma
data.verifiedAt	DateTime	Verification timestamp	2026-06-28T11:00:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Loan not in UNDER_VERIFICATION status	Loan must be in UNDER_VERIFICATION status to verify
400	Remarks too short	remarks must be at least 10 characters
400	Recommended amount exceeds applied amount	recommendedAmount cannot exceed the applied loanAmount
403	Wrong role	Only LOAN_OFFICER role can verify loans
404	Loan not found	Loan application with ID 501 not found

Business Rules

- Only loans in UNDER_VERIFICATION status can be verified.
- Loan Officer cannot approve or reject — only verify and recommend.
- Recommended amount cannot exceed the originally applied loan amount.

5.2 Approve Loan (Checker — Credit Manager)

POST /api/v1/approvals/{loanId}/approve — Credit Manager approves a verified loan

Property	Value
Method	POST
Endpoint	/api/v1/approvals/{loanId}/approve
Description	Credit Manager approves a verified loan
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CREDIT_MANAGER

Path Parameters

Parameter	Type	Required	Description
loanId	Long	Yes	ID of the loan in VERIFIED status

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
approvedAmount	Decimal	Yes	Final approved amount. Must be <= recommendedAmount from verification.	500000.00
interestRate	Decimal	Yes	Annual interest rate in %. Min: 7.0 Max: 36.0	12.5
remarks	String	Yes	Min 10, Max 1000 chars. Approval justification.	Approved based on CIBIL score and income.

Response Body — Field Specification

Field Name	Type	Description	Example
data.loanStatus	Enum	Updated status = APPROVED	APPROVED
data.approvedAmount	Decimal	Final approved amount in INR	500000.00
data.interestRate	Decimal	Applied interest rate	12.5
data.approvedAt	DateTime	Approval timestamp	2026-06-28T14:00:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Loan not in VERIFIED status	Loan must be in VERIFIED status to approve
400	Approved amount too high	approvedAmount cannot exceed the verified recommendedAmount
403	Wrong role	Only CREDIT_MANAGER role can approve loans

HTTP Code	Scenario	Error Message
404	Loan not found	Loan application with ID 501 not found

Business Rules

- Only VERIFIED loans can be approved.
- Approved amount cannot exceed the Loan Officer's recommended amount.
- Interest rate must be between 7.0% and 36.0% per annum.
- Approval triggers automatic EMAIL + SMS notification to customer.

5.3 Reject Loan

POST `/api/v1/approvals/{loanId}/reject` — Credit Manager rejects a verified loan

Property	Value
Method	POST
Endpoint	/api/v1/approvals/{loanId}/reject
Description	Credit Manager rejects a verified loan
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CREDIT_MANAGER

Path Parameters

Parameter	Type	Required	Description
loanId	Long	Yes	ID of the loan in VERIFIED status

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
rejectionReason	String	Yes	Min 10, Max 500 chars. Reason for rejection.	Low CIBIL score. Score below 650.
remarks	String	Yes	Min 10, Max 1000 chars. Detailed rejection remarks.	Customer may re-apply after 6 months.

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Loan not in VERIFIED status	Loan must be in VERIFIED status to reject
403	Wrong role	Only CREDIT_MANAGER role can reject loans
404	Loan not found	Loan application with ID 501 not found

Business Rules

- Rejection triggers automatic EMAIL + SMS notification to customer with rejection reason.
- Rejected customer may re-apply with a new application.

Module 6 — EMI APIs

Base Path: /api/v1/emi
Handles EMI calculation, schedule generation, and repayment tracking for approved loans.

6.1 Calculate EMI

POST /api/v1/emi/calculate — Calculate EMI without applying for a loan (public tool)

Property	Value
Method	POST
Endpoint	/api/v1/emi/calculate
Description	Calculate EMI without applying for a loan (public tool)
Auth Required	No
Allowed Roles	PUBLIC

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
loanAmount	Decimal	Yes	Principal amount in INR. Min: 10,000 Max: 5,000,000	500000
interestRate	Decimal	Yes	Annual interest rate in %. Min: 7.0 Max: 36.0	12.5
loanTenureMonths	Integer	Yes	Loan tenure in months. Min: 6 Max: 84	36

Response Body — Field Specification

Field Name	Type	Description	Example
data.loanAmount	Decimal	Principal loan amount	500000.00
data.interestRate	Decimal	Annual interest rate (%)	12.5
data.tenureMonths	Integer	Loan tenure in months	36

Field Name	Type	Description	Example
data.monthlyEMI	Decimal	Monthly EMI amount in INR	16680.00
data.totalInterest	Decimal	Total interest paid over tenure	100480.00
data.totalRepayment	Decimal	Total amount repaid (principal + int)	600480.00

Possible Error Responses

HTTP Code	Scenario	Error Message
400	loanAmount below minimum	loanAmount must be at least 10,000
400	interestRate out of range	interestRate must be between 7.0 and 36.0
400	loanTenureMonths out of range	loanTenureMonths must be between 6 and 84

Note: EMI Formula: $EMI = P \times r \times (1+r)^n / ((1+r)^n - 1)$, where P = Principal, r = Monthly Rate (Annual/12/100), n = Tenure in Months

6.2 Get EMI Schedule

GET /api/v1/emi/{loanId}/schedule — Get full month-by-month EMI repayment schedule for an approved loan

Property	Value
Method	GET
Endpoint	/api/v1/emi/{loanId}/schedule
Description	Get full month-by-month EMI repayment schedule for an approved loan
Auth Required	Yes — Bearer JWT Token
Allowed Roles	CUSTOMER, LOAN_OFFICER

Path Parameters

Parameter	Type	Required	Description
loanId	Long	Yes	ID of an APPROVED or DISBURSED loan

Response Body — Field Specification

Field Name	Type	Description	Example
loanId	Long	Loan identifier	501
totalEMIs	Integer	Total number of EMI installments	36
monthlyEMI	Decimal	Fixed monthly EMI amount	16680.00
schedule[].month	Integer	EMI installment number (1 to n)	1
schedule[].dueDate	Date	EMI due date	2026-08-01
schedule[].emi	Decimal	Total EMI for this month	16680.00
schedule[].principal	Decimal	Principal component for this month	10597.00
schedule[].interest	Decimal	Interest component for this month	6083.00
schedule[].balance	Decimal	Remaining principal after this EMI	489403.00
schedule[].status	Enum	PENDING / PAID / OVERDUE	PENDING

Possible Error Responses

HTTP Code	Scenario	Error Message
401	Unauthorized	Authentication token is missing or invalid
403	Customer accessing another's schedule	You do not have permission to view this loan
404	Loan not found	Loan with ID 501 not found
422	EMI schedule not yet generated	EMI schedule is only available after loan is APPROVED

Business Rules

- EMI schedule is auto-generated once loan reaches APPROVED status.
- First EMI due date is 30 days after disbursement date.
- CUSTOMER role can only view their own loan's EMI schedule.

Module 7 — Notification APIs

Base Path: /api/v1/notifications

Manages system notifications sent to users. Notifications are auto-triggered at key loan lifecycle events.

7.1 Get All Notifications

GET /api/v1/notifications — Get all notifications for the currently logged-in user

Property	Value
Method	GET
Endpoint	/api/v1/notifications
Description	Get all notifications for the currently logged-in user
Auth Required	Yes — Bearer JWT Token
Allowed Roles	ALL AUTHENTICATED ROLES

Query Parameters

Parameter	Type	Required	Default	Description
page	Integer	No	0	Page number (0-indexed)
size	Integer	No	20	Notifications per page. Max: 50
read	Boolean	No	—	Filter by read status: true = read only, false = unread only
type	String	No	—	Filter by notification type: EMAIL, SMS, IN_APP

Response Body — Field Specification

Field Name	Type	Description	Example
content[].notificationId	Long	Notification unique ID	301
content[].title	String	Notification heading	Congratulations! Your loan is approved.

Field Name	Type	Description	Example
content[].message	String	Notification body text	Loan #LOAN20260628001 has been approved for ₹5,00,000.
content[].type	Enum	Notification type: EMAIL / SMS / IN_APP	IN_APP
content[].isRead	Boolean	Read status: true = read, false = unread	false
content[].createdAt	DateTime	Notification creation timestamp	2026-06-28T14:05:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
401	Unauthorized	Authentication token is missing or invalid

7.2 Auto-Triggered Notification Events

Loan Event	Trigger Condition	Notification Type	Channel
User Registration	New user registers	Welcome Email	EMAIL
Loan Submitted	Customer submits loan application	Application Received	EMAIL, SMS
Documents Required	Loan moved to SUBMITTED	Upload Reminder	EMAIL, IN-APP
Loan Under Verification	Officer picks up loan	Under Review	EMAIL, IN-APP
Loan Approved	Credit Manager approves	Congratulations!	EMAIL, SMS, IN-APP
Loan Rejected	Credit Manager rejects	Application Update	EMAIL, SMS
Loan Disbursed	Finance disburses amount	Amount Credited	EMAIL, SMS, IN-APP
EMI Reminder	3 days before EMI due date	EMI Due Alert	EMAIL, SMS, IN-APP
EMI Overdue	EMI due date passed without payment	Overdue Alert	EMAIL, SMS, IN-APP

Module 8 — Admin APIs

Base Path: /api/v1/admin

Accessible only by ADMIN role. Provides user management, system reporting, audit logs, and loan type configuration.

8.1 Change User Status

PATCH /api/v1/admin/users/{userId}/status — Activate, lock, or suspend a user account

Property	Value
Method	PATCH
Endpoint	/api/v1/admin/users/{userId}/status
Description	Activate, lock, or suspend a user account
Auth Required	Yes — Bearer JWT Token
Allowed Roles	ADMIN

Path Parameters

Parameter	Type	Required	Description
userId	Long	Yes	Unique ID of the user to update

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
status	Enum	Yes	ACTIVE LOCKED SUSPENDED	LOCKED
reason	String	Yes	Min 5, Max 500 chars. Reason for status change.	Multiple failed login attempts

Response Body — Field Specification

Field Name	Type	Description	Example
data.userId	Long	User ID updated	42
data.status	String	New user status	LOCKED
data.updatedAt	DateTime	Timestamp of change	2026-06-28T15:00:00Z

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Missing or invalid status value	status must be one of: ACTIVE, LOCKED, SUSPENDED
400	Reason too short	reason must be at least 5 characters
403	Non-ADMIN user	Only ADMIN role can change user status
404	User not found	User with ID 42 not found
422	Admin trying to lock themselves	Admin cannot lock their own account

Business Rules

- LOCKED users cannot log in. Account must be set back to ACTIVE by an Admin.
- SUSPENDED users lose access and must contact support.
- Admin cannot modify their own status.
- All status changes are recorded in the audit log.

8.2 Get Audit Logs

GET /api/v1/admin/audit-logs — Get system audit logs for all API actions

Property	Value
Method	GET
Endpoint	/api/v1/admin/audit-logs
Description	Get system audit logs for all API actions
Auth Required	Yes — Bearer JWT Token
Allowed Roles	ADMIN

Query Parameters

Parameter	Type	Required	Default	Description
page	Integer	No	0	Page number
size	Integer	No	20	Records per page. Max: 100
userId	Long	No	—	Filter by specific user ID
action	String	No	—	Filter by action type (LOGIN, LOAN_SUBMIT, etc.)
fromDate	Date	No	—	Start date filter: yyyy-MM-dd
toDate	Date	No	—	End date filter: yyyy-MM-dd

Response Body — Field Specification

Field Name	Type	Description	Example
content[].logId	Long	Audit log entry ID	9001
content[].userId	Long	User who performed the action	42
content[].action	String	Action performed	LOAN_SUBMITTED
content[].entity	String	Affected entity type	Loan
content[].entityId	Long	Affected entity ID	501
content[].ipAddress	String	Client IP address	192.168.1.100
content[].timestamp	DateTime	When action was performed	2026-06-28T10:15:00Z
content[].result	String	SUCCESS or FAILURE	SUCCESS

Possible Error Responses

HTTP Code	Scenario	Error Message
401	Unauthorized	Authentication token is missing or invalid
403	Non-ADMIN	Only ADMIN role can access audit logs

Business Rules

- All API calls are automatically logged. Audit logs cannot be deleted.
- Logs are retained for a minimum of 7 years as per compliance requirements.

8.3 Create Loan Type

POST /api/v1/admin/loan-types — Create a new loan type configuration

Property	Value
Method	POST
Endpoint	/api/v1/admin/loan-types
Description	Create a new loan type configuration
Auth Required	Yes — Bearer JWT Token
Allowed Roles	ADMIN

Request Body — Field Specification

Field Name	Type	Required	Validation Rules	Example
name	String	Yes	Min 3, Max 100 chars. Unique loan type name.	Personal Loan
description	String	No	Max 500 chars. Description of the loan type.	Unsecured personal loan for individuals
minAmount	Decimal	Yes	Minimum loan amount in INR. Min: 1000.	10000.00
maxAmount	Decimal	Yes	Maximum loan amount in INR. Must be > minAmount.	5000000.00
minTenureMonths	Integer	Yes	Minimum tenure in months. Min: 1.	6
maxTenureMonths	Integer	Yes	Maximum tenure in months. Must be > minTenureMonths.	84
baseInterestRate	Decimal	Yes	Base interest rate in % per annum. Min: 7.0 Max: 36.0	12.5
isActive	Boolean	No	Active flag. Default: true	true

Possible Error Responses

HTTP Code	Scenario	Error Message
400	Duplicate loan type name	Loan type with this name already exists
400	maxAmount <= minAmount	maxAmount must be greater than minAmount
400	Invalid interest rate range	baseInterestRate must be between 7.0 and 36.0
403	Non-ADMIN user	Only ADMIN role can create loan types

Error Codes & Security Reference

HTTP Status Codes

Status Code	Name	When Used
200	OK	Successful GET, PUT, PATCH operations
201	Created	Successful POST — new resource created
204	No Content	Successful DELETE — no body returned
400	Bad Request	Invalid input, missing fields, validation failure
401	Unauthorized	JWT token missing, expired, or invalid
403	Forbidden	Valid token but insufficient role/permissions
404	Not Found	Requested resource does not exist
409	Conflict	Duplicate entry — email, PAN, or mobile already exists
422	Unprocessable Entity	Business rule violation — valid format but logic error
429	Too Many Requests	Rate limit exceeded (100 requests/minute per IP)
500	Internal Server Error	Unexpected server-side error
503	Service Unavailable	System under maintenance or downstream failure

Role Permissions Matrix

Action	CUSTOMER	LOAN_OFFICER	CREDIT_MANAGER	FINANCE_OFFICER	ADMIN
Register / Login	✓	✓	✓	✓	✓
View Own Profile	✓	—	—	—	✓
Submit Loan	✓	—	—	—	—
Upload Documents	✓	—	—	—	—
View All Loans	—	✓	✓	✓	✓
Verify Loan	—	✓	—	—	—
Approve / Reject	—	—	✓	—	—
Sanction / Disburse	—	—	—	✓	—

Action	CUSTOMER	LOAN_OFFICER	CREDIT_MANAGER	FINANCE_OFFICER	ADMIN
Manage Users	—	—	—	—	✓
View Audit Logs	—	—	—	—	✓
Create Loan Types	—	—	—	—	✓

Security Mechanisms

Mechanism	Details
JWT Authentication	Bearer token in Authorization header — expires in 24 hours
Refresh Token	Long-lived token (7 days) to get new access tokens without re-login
Role-Based Access	5 roles: CUSTOMER, LOAN_OFFICER, CREDIT_MANAGER, FINANCE_OFFICER, ADMIN
HTTPS Only	All APIs served over TLS/SSL. HTTP requests are rejected.
Password Hashing	BCrypt with strength 10 — never stored in plaintext
Input Validation	All inputs validated at controller layer using Bean Validation (@Valid)
SQL Injection Prevention	Spring Data JPA + Parameterized Queries — no raw SQL
Rate Limiting	Max 100 requests/minute per IP — returns HTTP 429 if exceeded
CORS Policy	Only whitelisted origins allowed — configurable per environment
Audit Logging	All API calls logged with user ID, IP, timestamp, and action result
Account Lockout	Account locked after 5 consecutive failed login attempts